

Module 18

Active Directory Fundamentals

Memahami identity, authentication, directory structure, policy, DNS, trust, dan object relationships sebelum masuk AD enumeration & attack paths.

Target akhir Lo bisa melihat environment AD sebagai graph identitas dan kepercayaan: siapa user-nya, komputer apa saja, domain/forest mana, bagaimana DNS menemukan DC, bagaimana Kerberos/NTLM bekerja, bagaimana GPO dan group membership memengaruhi privilege, serta data apa yang perlu dikumpulkan secara aman untuk Module 19.

Prerequisite	Output
Module 01-05	Nyaman dengan Linux/Windows CLI, networking, HTTP, PowerShell/Python.
Module 06-08	Paham scope, evidence, DNS, service discovery, dan enumeration mindset.
Module 17	Paham token, SID, ACL, service/task/registry basics di Windows.
Module 18 deliverable	AD topology map + DNS/SRV evidence + identity/group map + Kerberos/GPO/trust notes.

Learning path module ini

Bagian	Fokus
A. Mental model	AD DS, forest, domain, OU, object, security boundary.
B. Identity	SID, GUID, UPN, sAMAccountName, users, groups, computers.
C. Discovery	DNS, SRV records, DC Locator, LDAP distinguished names.
D. Authentication	Kerberos, TGT/TGS, KDC, NTLM fallback, SPN.
E. Policy & trust	GPO, SYSVOL, trusts, group scopes, Global Catalog/FSMO.
F. Hands-on	Read-only inventory + GOAD/MINILAB-oriented practice + capstone map.

1. Kenapa Active Directory penting untuk Red Team

Active Directory Domain Services (AD DS) adalah directory service hierarkis yang menyimpan object jaringan seperti user, computer, group, service identity, policy, dan relationship antar-object. Dalam enterprise Windows, AD bukan sekadar “server login”; ia menjadi control plane untuk identitas, authorization, naming, dan konfigurasi banyak host sekaligus.

- Kalau lo tidak paham AD, banyak attack path enterprise akan terlihat seperti kumpulan command tanpa konteks.
- Kalau lo paham AD, lo bisa membaca environment sebagai graph: identity → membership → permission → object → host/service → trust.
- Tujuan Module 18 bukan menyerang domain, tetapi membangun mental model agar Module 19 (enumeration) dan Module 20 (Kerberos/attack paths) masuk akal.

Boundary modul Semua script di package ini read-only. Tidak ada password spraying, Kerberoasting, relay, credential dumping, ACL abuse, GPO abuse, persistence, atau lateral movement. Aktivitas ofensif tersebut dibahas nanti hanya dalam authorized lab.

AD DS vs Microsoft Entra ID

Teknologi	Mental model singkat
AD DS	Directory on-prem/traditional: LDAP, Kerberos/NTLM, domain join, Group Policy, trusts, domain controllers.
Microsoft Entra ID	Cloud identity platform untuk SaaS/cloud apps; bukan “AD DS di cloud” dan tidak memakai domain controller tradisional.
Entra Domain Services	Managed domain service yang menyediakan subset compatible seperti domain join, LDAP, Kerberos/NTLM, dan Group Policy.

2. Logical Model: Forest → Domain → OU → Object

Microsoft mendeskripsikan forest sebagai top-level logical container. Satu forest dapat berisi satu atau lebih domain yang berbagi schema, configuration partition, dan Global Catalog. Di dalam domain, OU dipakai untuk pengelompokan administratif, delegation, dan Group Policy.

```

FOREST: corp.example
├── DOMAIN: corp.example
│   ├── OU=Users
│   │   ├── CN=alice
│   │   └── CN=bob
│   ├── OU=Servers
│   │   └── CN=APP01
│   ├── OU=Workstations
│   │   └── CN=WS01
└── DOMAIN: child.corp.example
    └── OU=Engineering
  
```

Konsep	Yang perlu lo ingat
Forest	Collection domain yang berbagi schema/configuration/GC. Domain dalam forest punya transitive trust otomatis.
Domain	Directory partition + authentication/authorization scope + replication unit untuk domain data.
OU	Container administratif. Dipakai untuk delegation dan GPO targeting; bukan security group.
Object	User, group, computer, service account, GPO, OU, dsb. Punya attributes dan security descriptor.

Red Team perspective Jangan melihat OU sebagai “folder cantik”. ACL pada OU dan inheritance dapat menentukan siapa boleh membuat, mengubah, atau mengendalikan object di bawahnya. Ini baru akan kita eksplor lebih dalam di Module 19-20.

Forest sebagai security boundary

Secara desain klasik, forest diperlakukan sebagai security boundary AD karena forest-wide roles dan schema/configuration bersifat bersama. Domain membantu administrative partitioning, tetapi kompromi highly privileged forest-level identities dapat berdampak lintas-domain. Untuk belajar, anggap setiap trust dan forest boundary sebagai hubungan yang harus dipetakan, bukan diasumsikan aman.

3. Identity & Object Identifiers

Nama yang terlihat manusia bukan identifier keamanan utama. Windows dan AD memakai beberapa identifier berbeda karena object dapat di-rename atau dipindahkan.

Identifier	Contoh	Makna
SID	S-1-5-21-...-1105	Security identifier; muncul di token/ACL. RID biasanya bagian terakhir.
objectGUID	a1b2...	Identifier object directory yang stabil dan unik.
sAMAccountName	alice	Nama kompatibilitas lama/NetBIOS logon.
UPN	alice@corp.example	User Principal Name; format login modern di domain.
DN	CN=Alice,OU=Users,DC=corp,DC=example	Posisi object di directory tree.

Users, computers, groups, service identities

- User object mewakili human atau service identity; jangan menganggap semua user adalah manusia.
- Computer object juga security principal dan punya machine account credentials.
- Security group dapat muncul dalam ACL/token dan menjadi jalur permission.
- Distribution group bukan security-enabled sehingga tidak dipakai untuk DACL authorization.

Group scope

Scope	Membership	Permission reach
Global	Accounts/groups dari domain yang sama	Dapat diberi permission di domain lain dalam forest/trust sesuai aturan.
Domain Local	Accounts/groups dari trusted domains/forest	Umumnya permission diberikan pada resource di domain tersebut.
Universal	Accounts/groups dari forest	Dapat dipakai lintas-domain di forest/trusting forest.

Mental shortcut AGDLP sering dipakai sebagai pola desain: Accounts → Global groups → Domain Local groups → Permissions. Ini bukan hukum mutlak, tapi membantu membaca nested group relationships.

4. Domain Controller, DNS, dan DC Locator

Domain Controller (DC) menyimpan replica directory dan menyediakan authentication serta directory services. Client harus bisa menemukan DC yang tepat. Di AD modern, DNS sangat penting: DC mendaftarkan locator records, termasuk SRV records untuk LDAP, Kerberos KDC, dan Global Catalog.

```
_ldap._tcp.dc._msdcs.corp.example SRV 0 100 389 dc01.corp.example
_kerberos._tcp.corp.example SRV 0 100 88 dc01.corp.example
_gc._tcp.corp.example SRV 0 100 3268 dc01.corp.example
```

DC Locator menggunakan DNS-based discovery. Karena itu “DNS salah” sering terlihat seperti “AD rusak”: domain join gagal, Kerberos gagal, GPO lambat, atau client menemukan DC yang salah.

Port umum	Service	Catatan
53/TCP+UDP	DNS	Name resolution dan locator records.
88/TCP+UDP	Kerberos	KDC authentication/ticketing.
389/TCP+UDP	LDAP / CLDAP	Directory queries dan locator checks.
445/TCP	SMB	SYSVOL/NETLOGON dan file services.
464/TCP+UDP	Kerberos password change	Password set/change via Kerberos.
636/TCP	LDAPS	LDAP over TLS.
3268/3269	Global Catalog / GC TLS	Forest-wide partial attribute search.

Common mistake Memasukkan public DNS seperti 8.8.8.8 sebagai DNS utama domain-joined Windows biasanya memutuskan kemampuan client menemukan AD-specific records. Di lab, workstation seharusnya menunjuk ke DNS/DC lab yang benar.

5. LDAP & Distinguished Names

LDAP adalah protocol untuk mengakses directory data. AD menyimpan object dalam hierarchical namespace. Distinguished Name (DN) menunjukkan posisi object, sedangkan Relative Distinguished Name (RDN) adalah komponen paling kiri untuk object tersebut.

DN : CN=Alice,OU=Engineering,OU=Users,DC=corp,DC=example
 RDN : CN=Alice
 Base: DC=corp,DC=example

Prefix	Makna
DC=	Domain Component
OU=	Organizational Unit
CN=	Common Name

Enumeration tool nantinya akan melakukan LDAP queries dengan kombinasi base DN, filter, attributes, dan scope. Sebelum memakai tool otomatis, lo harus bisa membaca DN dan memahami apakah sebuah object berada di domain/OU yang benar.

Schema

Schema mendefinisikan class dan attribute apa yang boleh ada di directory. User, computer, group, dan custom application object semuanya mengikuti schema. Karena schema bersifat forest-wide, perubahan schema adalah operasi high-impact dan membership Schema Admins sangat sensitif.

6. Kerberos: ticket-based authentication

Kerberos adalah authentication protocol utama pada AD ketika client dan service mendukungnya. Alih-alih mengirim password ke setiap server, client memperoleh ticket dari Key Distribution Center (KDC), yang biasanya berjalan pada DC.

- 1) User logon
 Client — AS-REQ —> KDC
 Client <- AS-REP / TGT — KDC
- 2) Akses service CIFS/app01.corp.example
 Client — TGS-REQ + TGT -> KDC
 Client <- TGS-REP / service ticket — KDC
- 3) Client — service ticket -> APP01

Istilah	Makna
KDC	Key Distribution Center; menyediakan Authentication Service dan Ticket Granting Service.
TGT	Ticket Granting Ticket; dipakai untuk meminta service ticket.
TGS/service ticket	Ticket untuk service tertentu yang diidentifikasi SPN.
PAC	Authorization data Windows yang biasanya memuat identity/group information.

Kenapa penting Banyak AD attack path lanjutan berakar dari ticket, service account, delegation, SPN, atau key material. Di Module 18 cukup pahami alur normal dulu; jangan lompat ke “roasting” sebelum bisa menjelaskan TGT vs TGS.

Klist sebagai observability tool

```
klist
```

```
# Windows dapat menampilkan Kerberos tickets yang ada pada logon session saat ini.
```

7. NTLM: challenge-response & fallback

NTLM masih ada untuk compatibility dan situasi ketika Kerberos tidak tersedia. Secara konseptual, server mengirim challenge, client membuat response berbasis credential material, lalu server/domain controller memvalidasi. NTLM tidak memberi mutual authentication seperti Kerberos dan punya security properties yang lebih lemah.

Kerberos	NTLM
Ticket-based; memakai KDC dan SPN.	Challenge-response; compatibility/fallback.
Mendukung mutual authentication.	Tidak memberi server identity assurance yang sama.
Sangat bergantung DNS, time sync, SPN.	Sering muncul ketika Kerberos tidak dapat dipakai.

Blue Team perspective Environment modern biasanya berusaha mengurangi NTLM dan memonitor penggunaannya. Untuk Red Team, melihat NTLM berarti memahami alasan fallback-nya, bukan langsung menganggap relay pasti memungkinkan.

8. Service Principal Names (SPN)

SPN adalah identifier unik untuk instance service. Kerberos memakai SPN untuk menghubungkan service instance dengan account yang menjalankan service tersebut. Satu SPN tidak boleh terdaftar pada lebih dari satu account.

```
HTTP/app01.corp.example
CIFS/files01.corp.example
MSSQLSvc/sql01.corp.example:1433
```

Client menyusun SPN untuk service yang ingin diakses, kemudian meminta service ticket dari KDC. Karena SPN terikat ke account, service account dan SPN menjadi bagian penting dalam attack-surface mapping AD.

Fundamental dulu Di module ini kita hanya inventory/list SPN secara read-only. Ticket cracking atau Kerberoasting masuk Module 20 setelah lo benar-benar paham service ticket dan account relationship.

9. Group Policy, SYSVOL, dan inheritance

Group Policy Object (GPO) menyimpan policy settings dan dapat di-link ke site, domain, atau OU. Processing secara umum mengikuti LSDOU: Local → Site → Domain → OU, dengan policy yang lebih dekat ke object biasanya diproses lebih akhir dan dapat menimpa setting sebelumnya.

```

Local GPO
↓
Site-linked GPO
↓
Domain-linked GPO
↓
Parent OU GPO
↓
Child OU GPO

```

GPO punya komponen directory di AD dan file-based component pada SYSVOL. Karena GPO mengontrol banyak host/user sekaligus, permission untuk membuat/edit/link GPO sangat sensitif.

Konsep	Pertanyaan saat enumeration
Link	GPO ini di-link ke site/domain/OU mana?
Scope	User/computer mana yang benar-benar terkena?
Security filtering	Principal mana yang punya Apply Group Policy?
Inheritance	Apakah Block Inheritance / Enforced mengubah urutan?
Delegation	Siapa boleh edit GPO atau link-nya?

10. Trusts, Global Catalog, Replication, FSMO

Trust relationships

Trust memungkinkan authentication dari satu domain/forest dipakai untuk mengakses resource di domain/forest lain sesuai authorization policy. Trust dapat memiliki arah (one-way/two-way), transitivity, dan scope. Jangan menyamakan “trusted” dengan “allowed access”: trust memungkinkan authentication path, tetapi ACL tetap menentukan access.

```

Domain A  — trust —>  Domain B
identity proof      resource authorization

```

Global Catalog

Global Catalog menyimpan partial replica dari object di forest untuk search dan beberapa authentication scenarios. GC membuat query lintas-domain lebih efisien tanpa menyimpan seluruh attribute setiap object dari semua domain.

Replication

Multi-DC domain mengandalkan replication agar directory changes menyebar. AD juga memiliki Sites/Subnets untuk mencerminkan topology jaringan dan membantu client menemukan DC yang dekat serta mengoptimalkan replication.

FSMO roles

Forest-wide	Domain-wide
Schema Master	RID Master
Domain Naming Master	PDC Emulator
	Infrastructure Master

FSMO tidak berarti semua authentication berhenti jika satu role holder down. Role-role ini menangani operasi tertentu yang tidak cocok dilakukan secara multi-master bersamaan.

11. Security Model yang harus bisa lo baca

Signal	Pertanyaan
Group membership	Nested group apa yang menambah effective privilege?
ACL	Siapa punya Read/Write/GenericAll/WriteDACL-like rights pada object?
Delegation	Siapa diberi control atas OU, GPO, service, atau computer object?
Service identity	Service berjalan sebagai account apa? SPN terdaftar di mana?
Trust	Identity dari domain lain bisa diautentikasi ke mana?
GPO	Policy mana mengubah local rights, group membership, firewall, scripts, atau security options?
DNS	Client menemukan DC/service melalui record apa?

Think like an attacker AD attack path jarang berdiri sendiri. Satu group membership kecil + ACL inheritance + service account + trust dapat membentuk jalur privilege. BloodHound nanti membantu visualisasi, tetapi kemampuan membaca hubungan manual tetap penting.

12. Lab Architecture untuk Module 18

Ada dua mode belajar. Pilih yang sesuai resource device lo. Jangan expose lab AD vulnerable ke internet.

Mode	Cocok untuk	Catatan
A. Windows VM standalone	Konsep token, DNS, klist, gpresult, PowerShell.	Tidak punya domain data nyata; bagus untuk fundamental command.
B. GOAD MINILAB / isolated AD	Domain, DNS SRV, LDAP, Kerberos, GPO, trust/object inventory.	MINILAB: 1 DC + 1 workstation. Full GOAD jauh lebih berat.

GOAD warning GOAD memang sengaja sangat vulnerable untuk pentest practice. Dokumentasi project memperingatkan agar environment tidak digunakan sebagai production recipe dan tidak diekspos ke internet. Gunakan host-only/internal network atau provider network yang benar-benar terisolasi.

Omarchy workstation layout

```

Omarchy attacker workstation
├── evidence / scripts / notes
├── isolated virtualization network
│   ├── Windows DC (lab)
│   └── Windows Workstation (lab)

```

Kalau resource terbatas, jangan memaksa full GOAD. Fokus dulu pada MINILAB atau platform hosted (HTB/THM) untuk latihan domain. Full GOAD dapat dipakai nanti ketika masuk attack paths multi-domain/forest.

13. Guided Hands-on Labs

Aturan lab Command di bawah read-only. Jalankan hanya pada Windows VM/domain lab sendiri atau platform training yang memberi authorization. Simpan evidence ke workspace, jangan commit credentials/tickets/private data ke repo publik.

- 1 Buat workspace** — Dari Omarchy, jalankan `./labs/workspace-init.sh module18-ad` untuk membuat folder scope, raw evidence, normalized data, notes, dan reports dengan permission ketat.

```
./labs/workspace-init.sh module18-ad
find module18-ad -maxdepth 2 -type d -print
```

- 2 Standalone Windows identity baseline** — Jalankan script read-only untuk merekam hostname, OS, local/domain identity, token groups, DNS config, routes, dan domain join status.

```
PowerShell -ExecutionPolicy Bypass -File .\labs\windows-domain-inventory.ps1 `
-OutputPath .\module18-ad\01-raw\windows-inventory.txt
```

- 3 Domain & DC discovery** — Jika mesin domain-joined, lihat domain dan DC yang ditemukan Netlogon. Bandingkan dengan DNS server yang dikonfigurasi.

```
whoami /upn
nltest /dsgetdc:corp.example
ipconfig /all
```

- 4 DNS SRV records dari Omarchy** — Gunakan DNS server lab/private dan query locator records. Wrapper menolak DNS server public supaya tidak salah target.

```
./labs/srv-query.sh 192.168.56.10 corp.example module18-ad/01-raw/dns-srv.txt
```

- 5 Distinguished Name parser** — Latih membaca DN secara offline tanpa domain. Parser memecah CN/OU/DC sehingga lo terbiasa membaca object path.

```
python labs/dn-parser.py 'CN=Alice,OU=Engineering,OU=Users,DC=corp,DC=example'
```

- 6 Kerberos ticket inventory** — Pada domain-joined Windows, lihat ticket cache dan catat TGT vs service ticket tanpa mengeksport credential material.

```
PowerShell -ExecutionPolicy Bypass -File .\labs\kerberos-report.ps1 `
-OutputPath .\module18-ad\01-raw\kerberos.txt
```

- 7 Group Policy result** — Gunakan gpresult untuk melihat effective policy pada current user/computer. Fokus ke applied GPO names dan scope, bukan mengubah policy.

```
PowerShell -ExecutionPolicy Bypass -File .\labs\gpo-report.ps1 `
-OutputPath .\module18-ad\01-raw\gpo.txt
```

- 8 Trust inventory** — Jika lab punya trust, gunakan `nltest /domain_trusts` untuk membuat relationship list. Pada single-domain MINILAB hasilnya bisa sangat sederhana.

```
PowerShell -ExecutionPolicy Bypass -File .\labs\trust-report.ps1 `
-OutputPath .\module18-ad\01-raw\trusts.txt
```

- 9 AD object inventory dengan RSAT** — Jika ActiveDirectory PowerShell module tersedia, kumpulkan sample users/groups/computers dengan batas jumlah object. Script tidak memodifikasi directory.

```
PowerShell -ExecutionPolicy Bypass -File .\labs\ad-object-inventory.ps1 `
-OutputDir .\module18-ad\02-normalized -Limit 100
```

- 10 SPN inventory** — Gunakan query read-only untuk account yang punya SPN. Tujuannya memetakan service identity, bukan meminta/crack service tickets.

```
Get-ADUser -LDAPFilter '(servicePrincipalName=*)' `
-Properties servicePrincipalName | `
Select-Object SamAccountName,servicePrincipalName
```

- 11 Build topology map** — Gabungkan domain, DC, user/group/computer sample, DNS SRV, GPO, dan trust ke satu JSON sederhana lalu generate Markdown map.

```
python labs/ad-topology.py `
--input labs/sample-topology.json `
--output module18-ad/04-report/ad-topology.md
```

- 12 Evidence manifest** — Hash seluruh raw/normalized evidence sehingga perubahan file bisa terdeteksi selama pembelajaran.

```
./labs/evidence-manifest.sh module18-ad
```

14. Capstone — Explain the Domain Before You Enumerate It

Scenario: lo mendapatkan akses ke authorized AD training workstation, tetapi belum boleh menjalankan offensive enumeration. Deliverable lo adalah menjelaskan environment hanya dari read-only signals.

Deliverable	Minimal isi
Domain map	Forest/domain name, DC, DNS server, domain-joined status.
Identity map	Current user, SID/groups, sample user/group/computer objects.
Auth map	Kerberos ticket types yang terlihat; apakah NTLM fallback terlihat dari context/log bila tersedia.
Policy map	Applied GPO names + OU/domain scope yang bisa disimpulkan.
Trust map	Trust relationship yang terlihat; jangan asumsi access.
Service map	Sample SPN → account/service relationship.
Evidence	Raw output + normalized notes + SHA-256 manifest.

Exit criteria Lo lulus Module 18 kalau bisa menjelaskan: forest vs domain vs OU, SID vs DN vs UPN, bagaimana DNS menemukan DC, alur TGT/TGS, perbedaan Kerberos/NTLM, fungsi SPN, GPO processing, group scopes, trust, Global Catalog, dan mengapa semua itu membentuk attack graph.

15. Cheat Sheet

Tujuan	Command	Tujuan	Command
Identity	whoami /all	Domain/DC	nltest /dsgetdc:<domain>
Trusts	nltest /domain_trusts	Kerberos	klist
Effective GPO	gpresult /r	DNS config	ipconfig /all
SRV lookup	nslookup -type=SRV ...	AD domain	Get-ADDomain / Get-ADForest
Objects	Get-ADUser / Group / Computer	SPN	Get-ADUser -LDAPFilter ...

Knowledge check

Pertanyaan 1-5	Pertanyaan 6-10
1. Kenapa OU bukan security group?	6. Apa fungsi SPN dan kenapa harus unik?
2. Apa perbedaan forest, domain, dan OU?	7. Kenapa trust tidak otomatis berarti access?
3. Kenapa DNS penting untuk Kerberos/domain join?	8. Urutan LSDOU digunakan untuk apa?
4. Bedakan SID, objectGUID, UPN, sAMAccountName, DN.	9. Bedakan Global, Domain Local, Universal.
5. Jelaskan TGT vs service ticket.	10. Kenapa full GOAD harus diisolasi dari internet?

Troubleshooting lab yang paling sering

Gejala	Cek dulu
Domain join / Kerberos gagal	DNS client menunjuk ke DNS/DC lab? Waktu host sinkron? Nama domain benar?
nltest tidak menemukan DC	SRV record tersedia? Route ke subnet lab? Firewall lab?
klist kosong	Current session benar-benar domain authenticated? Coba access resource domain lalu cek lagi.
Get-AD* tidak dikenal	RSAT / ActiveDirectory PowerShell module belum tersedia pada VM.
gpresult minim	Mesin/user belum domain-joined atau belum menerima domain GPO.
GOAD tidak reachable	Pastikan provider network host-only/internal dan attacker berada di subnet yang diizinkan.

Checklist sebelum Module 19

Harus bisa	Status
Baca DN dan turunkan domain/OU path	☐
Jelaskan alur DNS → DC Locator → Kerberos	☐
Bedakan TGT, service ticket, NTLM fallback, SPN	☐
Jelaskan GPO scope/inheritance dan group scopes	☐
Buat topology map + evidence manifest dari lab	☐

16. Referensi Utama

Microsoft / primary docs	Microsoft / lab references
AD DS overview Open reference	Logical model Open reference
DC Locator Open reference	Kerberos overview Open reference
Service Principal Names Open reference	AD Security Groups Open reference
Group Policy scope Open reference	Group Policy Objects Open reference
Orange Cyberdefense GOAD Open reference	GOAD MINILAB Open reference